



ZAP by
Checkmarx

ZAP by Checkmarx Scanning Report

Site: <http://172.31.1.20:8080>

Generated on Sun, 26 Jul 2026 17:39:32

ZAP Version: 2.17.0

ZAP by [Checkmarx](#)

Summary of Alerts

Risk Level	Number of Alerts
High	0
Medium	2
Low	3
Informational	2
False Positives:	0

Alerts

Name	Risk Level	Number of Instances
Content Security Policy (CSP) Header Not Set	Medium	Systemic
Missing Anti-clickjacking Header	Medium	4
Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)	Low	Systemic
Server Leaks Version Information via "Server" HTTP Response Header Field	Low	Systemic
X-Content-Type-Options Header Missing	Low	Systemic
Information Disclosure - Suspicious Comments	Informational	4
User Agent Fuzzer	Informational	Systemic

Alert Detail

Medium	Content Security Policy (CSP) Header Not Set
Description	Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
URL	http://172.31.1.20:8080

Node Name	http://172.31.1.20:8080
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/documentation.html
Node Name	http://172.31.1.20:8080/documentation.html
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/noredirect.html
Node Name	http://172.31.1.20:8080/noredirect.html
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/robots.txt
Node Name	http://172.31.1.20:8080/robots.txt
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/sitemap.xml
Node Name	http://172.31.1.20:8080/sitemap.xml
Method	GET
Attack	
Evidence	
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to set the Content-Security-Policy header.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Guides/CSP https://cheatsheetseries.owasp.org/cheatsheets/Content_Security_Policy_Cheat_Sheet.html https://www.w3.org/TR/CSP/ https://w3c.github.io/webappsec-csp/

	https://web.dev/articles/csp https://caniuse.com/#feat=contentsecuritypolicy https://content-security-policy.com/
CWE Id	693
WASC Id	15
Plugin Id	10038

Medium	Missing Anti-clickjacking Header
Description	The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
URL	http://172.31.1.20:8080
Node Name	http://172.31.1.20:8080
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/
Node Name	http://172.31.1.20:8080/
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/documentation.html
Node Name	http://172.31.1.20:8080/documentation.html
Method	GET
Attack	
Evidence	
Other Info	
URL	http://172.31.1.20:8080/noredirect.html
Node Name	http://172.31.1.20:8080/noredirect.html
Method	GET
Attack	
Evidence	
Other Info	
Instances	4
Solution	Modern Web browsers support the Content-Security-Policy and X-Frame-Options HTTP headers. Ensure one of them is set on all web pages returned by your site/app. If you expect the page to be framed only by pages on your server (e.g. it's part of a FRAMESET) then you'll want to use SAMEORIGIN, otherwise if you never expect the page

	to be framed, you should use DENY. Alternatively consider implementing Content Security Policy's "frame-ancestors" directive.
Reference	https://developer.mozilla.org/en-US/docs/Web/HTTP/Reference/Headers/X-Frame-Options
CWE Id	1021
WASC Id	15
Plugin Id	10020

Low	Server Leaks Information via "X-Powered-By" HTTP Response Header Field(s)
Description	The web/application server is leaking information via one or more "X-Powered-By" HTTP response headers. Access to such information may facilitate attackers identifying other frameworks/components your web application is reliant upon and the vulnerabilities such components may be subject to.
URL	http://172.31.1.20:8080
Node Name	http://172.31.1.20:8080
Method	GET
Attack	
Evidence	X-Powered-By: Undertow/1
Other Info	
URL	http://172.31.1.20:8080/jboss_community.png
Node Name	http://172.31.1.20:8080/jboss_community.png
Method	GET
Attack	
Evidence	X-Powered-By: Undertow/1
Other Info	
URL	http://172.31.1.20:8080/robots.txt
Node Name	http://172.31.1.20:8080/robots.txt
Method	GET
Attack	
Evidence	X-Powered-By: Undertow/1
Other Info	
URL	http://172.31.1.20:8080/sitemap.xml
Node Name	http://172.31.1.20:8080/sitemap.xml
Method	GET
Attack	
Evidence	X-Powered-By: Undertow/1
Other Info	
URL	http://172.31.1.20:8080/wildfly_logo.png
Node Name	http://172.31.1.20:8080/wildfly_logo.png

Method	GET
Attack	
Evidence	X-Powered-By: Undertow/1
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress "X-Powered-By" headers.
Reference	https://owasp.org/www-project-web-security-testing-guide/v42/4-Web_Application_Security_Testing/01-Information_Gathering/08-Fingerprint_Web_Application_Framework https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10037

Low	Server Leaks Version Information via "Server" HTTP Response Header Field	
Description	The web/application server is leaking version information via the "Server" HTTP response header. Access to such information may facilitate attackers identifying other vulnerabilities your web/application server is subject to.	
URL	http://172.31.1.20:8080/console	
Node Name	http://172.31.1.20:8080/console	
Method	GET	
Attack		
Evidence	WildFly/8	
Other Info		
URL	http://172.31.1.20:8080/favicon.ico	
Node Name	http://172.31.1.20:8080/favicon.ico	
Method	GET	
Attack		
Evidence	WildFly/8	
Other Info		
URL	http://172.31.1.20:8080/jboss_community.png	
Node Name	http://172.31.1.20:8080/jboss_community.png	
Method	GET	
Attack		
Evidence	WildFly/8	
Other Info		
URL	http://172.31.1.20:8080/wildfly.css	
Node Name	http://172.31.1.20:8080/wildfly.css	
Method	GET	

Attack	
Evidence	WildFly/8
Other Info	
URL	http://172.31.1.20:8080/wildfly_logo.png
Node Name	http://172.31.1.20:8080/wildfly_logo.png
Method	GET
Attack	
Evidence	WildFly/8
Other Info	
Instances	Systemic
Solution	Ensure that your web server, application server, load balancer, etc. is configured to suppress the "Server" header or provide generic details.
Reference	https://httpd.apache.org/docs/current/mod/core.html#servertokens https://learn.microsoft.com/en-us/previous-versions/msp-n-p/ff648552(v=pandp.10) https://www.troyhunt.com/shhh-dont-let-your-response-headers/
CWE Id	497
WASC Id	13
Plugin Id	10036

Low	X-Content-Type-Options Header Missing
Description	The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
URL	http://172.31.1.20:8080/favicon.ico
Node Name	http://172.31.1.20:8080/favicon.ico
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.20:8080/jboss_community.png
Node Name	http://172.31.1.20:8080/jboss_community.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type.

	At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.20:8080/noredirect.html
Node Name	http://172.31.1.20:8080/noredirect.html
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.20:8080/wildfly.css
Node Name	http://172.31.1.20:8080/wildfly.css
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
URL	http://172.31.1.20:8080/wildfly_logo.png
Node Name	http://172.31.1.20:8080/wildfly_logo.png
Method	GET
Attack	
Evidence	
Other Info	This issue still applies to error type pages (401, 403, 500, etc.) as those pages are often still affected by injection issues, in which case there is still concern for browsers sniffing pages away from their actual content type. At "High" threshold this scan rule will not alert on client or server error responses.
Instances	Systemic
Solution	Ensure that the application/web server sets the Content-Type header appropriately, and that it sets the X-Content-Type-Options header to 'nosniff' for all web pages. If possible, ensure that the end user uses a standards-compliant and modern web browser that does not perform MIME-sniffing at all, or that can be directed by the web application /web server to not perform MIME-sniffing.
Reference	https://learn.microsoft.com/en-us/previous-versions/windows/internet-explorer/ie-developer/compatibility/gg622941(v=vs.85) https://owasp.org/www-community/Security_Headers
CWE Id	693
WASC Id	15
Plugin Id	10021

Informational	Information Disclosure - Suspicious Comments
Description	The response appears to contain suspicious comments which may help an attacker.
URL	http://172.31.1.20:8080

Node Name	http://172.31.1.20:8080
Method	GET
Attack	
Evidence	at your option) any later version. ~ ~ Th
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "<!-- ~ JBoss, Home of Professional Open Source. ~ Copyright (c) 2011, Red Hat, Inc., and individual contributors ~ as indi", see evidence field for the suspicious comment/snippet.
URL	http://172.31.1.20:8080/
Node Name	http://172.31.1.20:8080/
Method	GET
Attack	
Evidence	at your option) any later version. ~ ~ Th
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "<!-- ~ JBoss, Home of Professional Open Source. ~ Copyright (c) 2011, Red Hat, Inc., and individual contributors ~ as indi", see evidence field for the suspicious comment/snippet.
URL	http://172.31.1.20:8080/documentation.html
Node Name	http://172.31.1.20:8080/documentation.html
Method	GET
Attack	
Evidence	at your option) any later version. ~ ~ Th
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "<!-- ~ JBoss, Home of Professional Open Source. ~ Copyright (c) 2011, Red Hat, Inc., and individual contributors ~ as indi", see evidence field for the suspicious comment/snippet.
URL	http://172.31.1.20:8080/noredirect.html
Node Name	http://172.31.1.20:8080/noredirect.html
Method	GET
Attack	
Evidence	at your option) any later version. ~ ~ Th
Other Info	The following pattern was used: \bLATER\b and was detected in likely comment: "<!-- ~ JBoss, Home of Professional Open Source. ~ Copyright (c) 2011, Red Hat, Inc., and individual contributors ~ as indi", see evidence field for the suspicious comment/snippet.
Instances	4

Solution	Remove all comments that return information that may help an attacker and fix any underlying problems they refer to.
Reference	
CWE Id	615
WASC Id	13
Plugin Id	10027

Informational	User Agent Fuzzer
Description	Check for differences in response based on fuzzed User Agent (eg. mobile sites, access as a Search Engine Crawler). Compares the response statuscode and the hashcode of the response body with the original response.
URL	http://172.31.1.20:8080/console
Node Name	http://172.31.1.20:8080/console
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 6.0; Windows NT 5.1)
Evidence	
Other Info	
URL	http://172.31.1.20:8080/console
Node Name	http://172.31.1.20:8080/console
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 7.0; Windows NT 6.0)
Evidence	
Other Info	
URL	http://172.31.1.20:8080/console
Node Name	http://172.31.1.20:8080/console
Method	GET
Attack	Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.1)
Evidence	
Other Info	
Instances	Systemic
Solution	
Reference	https://owasp.org/wstg
CWE Id	
WASC Id	
Plugin Id	10104